

Documentación de decisiones de diseño seguro-MediData Health

Decisión de diseño	Descripción	Problema que resuelve	Riesgo relacionado	Impacto esperado
Seudonimización en capa de acceso	Transformar IDs de pacientes y usuarios en tokens antes de ser procesados por el modelo de detección	Los datos sensibles se exponen durante el análisis; existe riesgo de reidentificación cruzando campos	Exposición de datos sensibles	Permite el análisis de patrones sin exponer información real de pacientes, cumpliendo con HIPAA
Estandarización de registros entre módulos	Definir un esquema común para todos los logs de acceso (fecha, usuario, tipo de historial, ubicación, dispositivo)	Los módulos del sistema registran eventos en formatos diferentes, dificultando la comparación y detección de anomalías	Registros inconsistentes, Validación deficiente de entradas	Facilita el análisis automatizado y la detección temprana de comportamientos anómalos
Modelo de detección con umbrales dinámicos	Algoritmo que aprende el patrón normal de cada usuario y alerta cuando se desvía (ej: accesos en horarios inusuales, volumen anormal de consultas)	No hay forma de identificar accesos sospechosos en tiempo real; las auditorías son reactivas	Gestión insegura de sesiones, Acceso no autorizado	Permite detección proactiva de accesos indebidos, reduciendo el tiempo de respuesta ante incidentes
Logging centralizado y cifrado	Todos los eventos de acceso se registran en un repositorio central con cifrado y auditoría inmutable	Los logs están dispersos en diferentes módulos, sin integridad ni trazabilidad; pueden ser alterados	Fallos de autenticación, Exposición de datos sensibles	Proporciona trazabilidad completa y evidencia confiable para investigaciones y cumplimiento regulatorio
Separación de responsabilidades por capas	Dividir el sistema en capas (ingesta, análisis, notificación) con interfaces bien definidas y controles de acceso entre ellas	Un compromiso en una capa podría comprometer todo el sistema	Acceso no autorizado, Inyección de código	Limita el alcance de un posible ataque; si una capa es comprometida, las demás permanecen seguras
Plan de respuesta a incidentes documentado	Procedimiento escrito con roles, responsabilidades, plazos de notificación y flujo de comunicación para autoridades y pacientes	No existe un protocolo claro sobre cómo actuar ante un incidente confirmado, quién toma decisiones o cómo notificar	Falta de procedimiento de respuesta	Asegura una respuesta rápida y coordinada, reduciendo el impacto legal y reputacional ante un incidente
Protección de credenciales y variables de entorno	Almacenar claves, tokens y credenciales en variables de entorno o secretos, nunca en código fuente	Las credenciales pueden estar expuestas en el código o en archivos de configuración	Acceso no autorizado, Errores de configuración	Evita la exposición accidental de credenciales en repositorios, reduciendo el riesgo de acceso no autorizado